PROPOSED INTEGRATED DRAFT — NOT APPROVED

For Council review only · Not authorised, effective or operational until formally approved

AIG-AGT-05 · The Council · AI GOVERNANCE

Agent Authority Graph

The model: the central object of the agentic layer

Field	Controlled value
Document title	Agent Authority Graph: Model
Version	1.6 draft
Status	Draft for Council review; pre-adoption
Author	AI Governance Lead
Date	12 October 2026
Purpose	Define the relational spine of the agentic layer: who delegated what authority to whom, and how it can be seen, bounded and revoked
Built to	Agentic AI Governance Design Principles (core principle; invariants: attribution, authority, controllability)
Populated from	Agent Record / ASBOM, the Authority & Delegations sheet (one row per edge)
Source	OWASP ASI03 Identity and Privilege Abuse, ASI07 Insecure Inter-Agent Communication, ASI08 Cascading Failures; Agent Control Standard (released 1 September 2026); Playbook Appendix F.3 and F.7.7
Classification	OFFICIAL
Change history	1.1 draft, 29 September 2026: QA remediation — applied findings QA-088, QA-093, QA-120, QA-128, QA-166 (see QA change log). Supersedes the unnumbered working draft of 19 September 2026. Final tidy-up: self-referencing cross-reference removed from the standards row(s) REQ-039. 1.2 draft, 30 September 2026: v3.9.1: standards cross-reference note updated to the 54-entry requirement inventory (AIG-AIMS-05 REQ-054, Civil Contingencies Act 2004, added). 1.3 draft, 1 October 2026: v3.9.3: standards cross-reference note cites the 55-entry requirement inventory (AIG-AIMS-05 REQ-055, NIST AI 600-1 Generative AI Profile, added). 1.4 draft, 2 October 2026: v3.9.5: standards cross-reference note cites the 56-entry requirement inventory (AIG-AIMS-05 REQ-056, SI 2026/425 ICO statutory code of practice on AI and automated decision-making, added). Proposed — for Council confirmation. 1.5 draft, 4 October 2026: v3.9.9: states when the graph is required (delegation or multiple agents, and every agent at T3 and above; Playbook F.3). Proposed — for Council confirmation. 1.6 draft, 12 October 2026: v3.9.10: standards cross-reference note cites the 58-entry requirement inventory (AIG-AIMS-05 REQ-057 DAMA-DMBOK and REQ-058 ISO/IEC 5259, added as voluntary data governance references). Proposed — for Council confirmation.

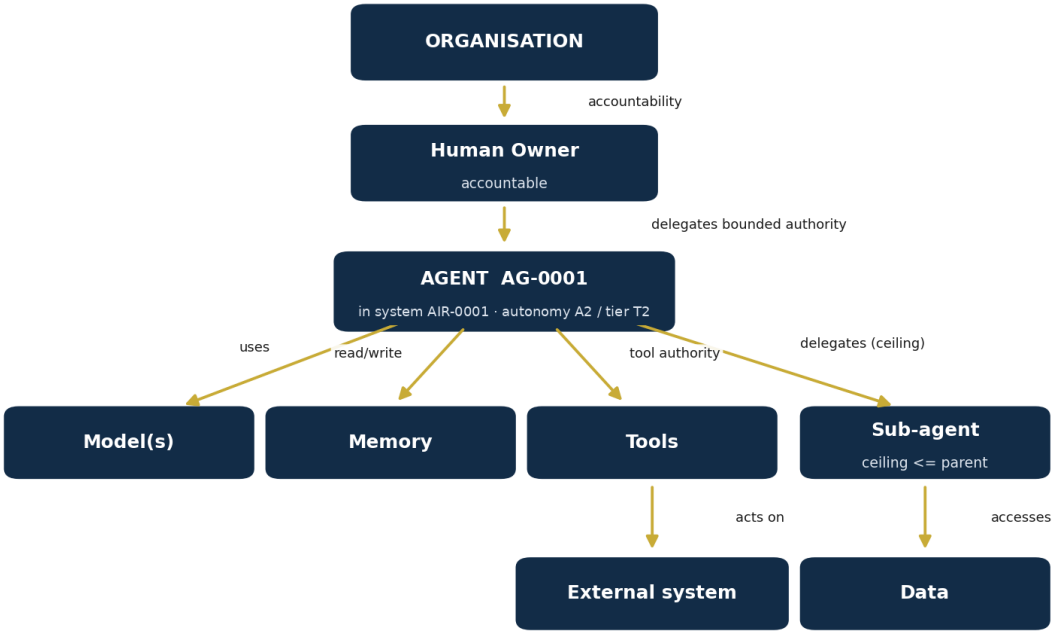
1. What it is, and why it is the central object

The Agent Authority Graph is the relational spine of the agentic layer. If the whole agentic governance model had to reduce to one object, it would be this. It records, as a graph, who delegated what authority to whom, through which mechanism, for what purpose, under what constraints, and how that authority

can be revoked. Every node is a party (an organisation, a human, an agent, a model, a tool, a sub-agent, a system or a dataset). Every authority edge is a delegation of capability or authority; links to models, memory, data or tools that carry no delegated authority are recorded as component or access relationships, not authority edges.

It matters because the hard questions in agentic governance are relational, not per-system. When a consequential action happens, the question is not which model wrote the final sentence but which actor held the authority at the moment the action occurred, and who delegated it to them. A flat register cannot answer that. The graph can.

2. The model at a glance



Each edge is a governed relationship (delegation, tool access or data access).

A worked example: the organisation is accountable through a named human owner, who delegates bounded authority to agent AG-0001 in system AIR-0001 (autonomy A2, tier T2). The agent holds tool authority and may delegate to a sub-agent under a ceiling no higher than its own (“delegates (ceiling)”); these are authority edges, each a governed delegation. The agent’s links to models (“uses”) and memory (“read/write”), and the sub-agent’s access link to data (“accesses”), are component or access relationships, not authority edges. Tools act on external systems (“acts on”) within the agent’s tool authority. Each edge in the figure is a governed relationship: a delegation, tool access or data access.

3. Nodes and edges

The graph is deliberately simple in structure so it stays legible as the estate grows.

- Node types: organisation, human, agent, model, memory, tool, API or MCP server, sub-agent, system, dataset. These are the component types already recorded in the ASBOM.
- Edge attributes: each edge carries the delegator, the delegatee, the authority delegated, the mechanism, the purpose, the UC-ID scope, the constraints or ceiling, the environment, any expiry, how it is revoked, whether it is inherited, and the edge type (authority, access, agent creation or replication), held on the ASBOM Authority & Delegations sheet (AIG-AGT-04; UC-ID scope, environment and edge type are proposed additions to that sheet). No edge without a revocation path.

Because the edges live in the ASBOM, the graph is a view of data you already hold rather than a separate thing to maintain. Add a delegation as a row; it becomes an edge. When required: wherever an agent can delegate to, or works with, other agents, and for every agent at T3 and above (Playbook F.3; Proposed — for Council confirmation). An agent with no delegation edges below T3 needs no graph.

4. What the graph lets you do that a register cannot

- Attribution: trace any consequential action back along its edges to the actor that held the authority and the human who delegated it (invariant: attribution).
- Blast radius: follow the edges outward from any node to see everything it can reach and therefore everything it could affect if it failed or were compromised (OWASP ASI08 cascading failures).
- Emergent risk: read the graph as a whole to find combinations that are each acceptable alone but unacceptable together, the emergent risk a per-system view misses.
- Authority ceilings: check that a sub-agent never inherits authority greater than its parent, and that no path accumulates more authority than any single grant intended (OWASP ASI03).
- Revocation: when something goes wrong, see every edge that must be cut to contain it, and confirm each has a revocation path before the agent ever goes live (invariant: controllability).

5. How it relates to the Capabilities and System Map

The suite also needs to describe broader use-case, capability and system interdependencies. AIG-AGT-05 is not that general service map: it derives agent authority/delegation paths from AIG-AGT-04. The proposed AIG-INV-05 Capabilities and System Map separately describes UC → CAP → system/component relationships, while AIG-AGT-05 answers which delegated authority crosses an agent/component edge and who granted it. They may be cross-referenced but neither replaces the other; the proposed map grants no permissions.

6. Keeping it current

- When it changes: an edge is added, changed or revoked whenever authority is delegated, altered or withdrawn, at a gate, on reauthorisation, or on a material change.
- Source of truth: the graph is generated from the ASBOM, so it is only ever as current as the record; keeping the Authority & Delegations sheet honest is the discipline that keeps the graph true.
- Review: at each reauthorisation the graph for that agent is re-read, and any edge without a live purpose or a working revocation path is a finding.

7. Status and source

Draft for Council review, pre-adoption; nothing evidenced until operated. The graph model realises OWASP's concerns with identity and privilege (ASI03), inter-agent communication (ASI07) and cascading failure (ASI08), and the traceability and control expectations of the Agent Control Standard (released 1 September 2026), verified against genai.owasp.org on 19 September 2026. The one-object framing follows Playbook Appendix F.3 (the record and the graph).

Draft for Council review. The relational spine; populated from the Agent Record / ASBOM.
Authority Graph control rules
• Every edge has a delegator, delegatee, authority, mechanism, purpose, UC-ID scope, ceiling, environment, expiry, revocation mechanism, inherited status and edge type (see §3).
Scope each authority edge and its purpose to the applicable UC-ID(s) under the parent AIR-ID; state explicit boundaries where an edge is shared. The graph describes delegation and constraints—it does not create delegated Council authority, approve a use, or replace the UC-ID-specific decision record. Unknown or conflicting scope must not be treated as permission.

• Authority inheritance is monotonic downward only: a child cannot exceed the effective authority of its parent.
• Memory, retrieved documents, tool output and agent-to-agent messages cannot create authority.
• Maximum delegation depth, recursion rules, concurrent-agent budget and transaction/financial budget are explicit graph constraints.
• Agent creation or replication is a separate authority edge and must not be implied by ordinary delegation.
• Containment of a parent must propagate to its governed children where technically applicable; residual exceptions must be recorded.

Status of this artefact

The Authority Graph is a derived governance view of the Agent Record/ASBOM. It should be generated or refreshed from recorded authority and delegation edges wherever technically possible. It is not intended to be a second manually maintained source of truth.

• Source of truth: Agent Record/ASBOM.
• Purpose: visualise authority, delegation, inheritance ceilings and boundary crossings.
• Update trigger: any material change to agent identity, authority, delegation, tools or interfaces.

Annex — Authority graph identity, derivation and traceability

PROPOSED INTEGRATION ONLY — This annex supplements the preserved source artefact; it does not amend or replace original text or tables and is not approved policy or permission to operate.

Identity contract

• AIR-ID is the permanent system key assigned on registration in AI Register (AIG-INV-04); a pre-registration discovery reference is provisional only. AG-ID is a stable, unique, non-recycled identifier for each individual agent. Pair each AG-ID with its parent AIR-ID; one AIR-ID may link to several AG-IDs. Preserve AG-ID across renaming/version changes and use controlled retirement/successor traceability, never reassignment.

• Every graph rendering/review cites the exact ASBOM (AIG-AGT-04) version/revision and identifiable snapshot/effective time.

Edges derived from ASBOM

• Generate/refresh edges from Authority & Delegations rows in the cited ASBOM (AIG-AGT-04) version. ASBOM is authoritative; graph is a derived representation, not a second registry or authority grant. Preserve source Edge ID and link each edge to ASBOM version and row/reference. Carry delegator/delegatee, authority, mechanism, purpose, constraints/ceiling, revocation, expiry and inherited status; distinguish authority edges from component/access relationships.

• Missing, conflicting, expired or untraceable source edges are exceptions to resolve, not values to infer. Update ASBOM first, then refresh and review the graph; graph update alone cannot authorise a changed envelope.

Action trace and re-entry

• AIG-AGT-06 records unique Action ID, AIR-ID, AG-ID, exact ASBOM version, invoked source edge(s) and execution evidence so action can be traced to the actor/delegator at that time. Cross-reference Action ID in AIG-OPS-03, AIG-OPS-02 and AIG-DEC-04 when incident, monitoring or gate follow-up applies. AIG-AGT-06/AIG-AGT-05 are not the gate decision.

• Discovery of unregistered AI or material changes in purpose, model, data, connection, tool, authority, composition or environment requires full Intake (AIG-INV-03) and triage re-entry; reconcile ASBOM and graph versions before consequential operation.

Status of this proposed copy

Relationship map versus authority graph

AIG-INV-05 and AIG-AGT-05 answer different questions. The proposed AIG-INV-05 map describes which outcome-led use cases rely on which reusable service capabilities and which systems/components are related. AIG-AGT-05 is only a derived view of agent authority/delegation paths from the exact AIG-AGT-04 ASBOM version; it is not a general capabilities inventory and grants no permission. Preserve both references where useful; resolve agent permissions in AIG-AGT-04 and system identity/current status in AIG-INV-04.

Proposed integrated draft; not approved and not effective. Original baseline content and tables are retained above. Formal approval, owner confirmation and document-control updates remain for the competent Council authority.

Standards and legal applicability — proposed QA cross-reference

PROPOSED QA INDEX — NOT APPROVED LEGAL ADVICE OR EVIDENCE OF COMPLIANCE. The listed instruments may be relevant to this artefact, but applicability depends on the case, service and Council delegation. Legislation, official guidance, Council policy and voluntary standards are different authority classes. The full 58-entry requirement inventory, authoritative URLs, validation owners and current versions are in AIG-AIMS-05; source checks are in AIG-AIMS-13. Do not treat a template, plan or cross-reference as completed assessment, adopted policy, ISO conformity or legal sign-off.

Requirement / instrument	Why check it here	Source
REQ-039 — NCSC Guidelines for Secure AI System Development	Screen the government security guidance requirement against this artefact's actual use and record evidence/version.	https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/introduction
REQ-040 — ISO/IEC 42001:2023 Artificial intelligence management system	Proposed management-system design mapping; licensed clause review and adoption needed.	https://www.iso.org/standard/42001
OWASP-ACS-2026 — OWASP Agent Control Standard (OWASP GenAI Security Project, released 1 September	Technical design guidance; verify operational tests	https://genai.owasp.org/resource/agent-control-standard-acs/

2026)